Project "Silent Shadow"

Passive Reconnaissance & Open-Source Intelligence (OSINT)

Course: Cybersecurity & Digital Forensics

Target: ikman.lk Online Marketplace

Name: Malindu Wijayarathna

Date: 27th February 2026

Table of Contents

Table of Contents 2

Executive Summary 3

Detailed Phase Analysis 4

Phase A: Infrastructure and DNS Mapping 4

Domain and Subdomains – Using crt.sh 4

DNS Records – Using dig 5

IP Space and ASN -Using BGP.he.net 8

Phase B: The Human Attack Surface 9

Employee Mapping – Using LinkedIn and Rocket Search 9

Email Pattern Analysis – Using Hunter.io 10

Breach History – Using HaveIBeenPwned 11

Phase C: Document and Metadata Mining 11

Google Dorking 11

Metadata Extraction – Using ExifTool 14

Phase D: Technical Stack Fingerprinting 14

Passive Profiling – Using Wappalyzer 14

Attack Surface Map 16

Risks Matrix 16

Remediation 17

Log of Tools 18

Executive Summary

This report presents the results of a passive reconnaissance (OSINT) operation conducted on ikman.lk, one of Sri Lanka's leading online marketplace platforms. The objective was to map the organizations publicly exposed digital attack surface, infrastructure footprint, and human asset visibility without performing any active scanning or leaving a footprint in the target's logs.

The assessment strictly followed passive reconnaissance methodology, relying only on publicly available information sources such as DNS records, certificate transparency logs, LinkedIn role mapping, Google Dorking techniques, metadata extraction from public documents and technology fingerprinting tools.

Key Findings:

Infrastructure and Cloud Protection: ikman.lk operates behind Cloudflare's CDN and security network, masking its origin servers and providing DDoS protection. This platform uses Amazon Web Services (AWS) for backend hosting and uses the Let's Encrypt Certificates for automated SSL management. Several operational subdomains such as admin, auth, payment, support, etc. were identified which increases the observable attack surface.

Email and SaaS Ecosystem: The DNS records indicate that ikman.lk uses Google Workspace for email services with properly configured SPF policy. The organization integrates multiple third-party services including Zendesk, Atlassian, Mandrill, and Facebook domain verifications. While these enhances its functionalities, it also increases the dependency on external SaaS platforms.

Technology Stack: The technology fingerprint reveals the use of WordPress, PHP, MySQL, and modern JavaScript libraries, along with analytics and marketing platforms such as Google Analytics (G4A), Snowplow, WebEngage, and Google Tag Manager. Security mechanisms such as HSTS and reCAPTCHA are enabled, indicating baseline security implementation.

Human Attack Surface: Publicly exposed employee names, roles and identifiable email patterns and some personal details were discovered. Technical and infrastructure related roles

are particularly valuable targets for phishing or social engineering attacks. This increases the likelihood of targeted Business Email Compromise (BEC) or credential harvesting attempts.

Public File Exposure: A third-party shortened URL inside a PDF was found that redirects to a downloadable ZIP file titled "ikman.lk". Although no malicious activity was confirmed, hosting branded files through external short URLs represents a potential brand impersonation and phishing risk.

Detailed Phase Analysis

Phase A: Infrastructure and DNS Mapping

Domain and Subdomains – Using crt.sh

The ikman.lk domain maintains multiple operational subdomains discovered through certificate transparency logs. All certificates are issued via Let's Encrypt, which indicates automated SSL Lifecycle management.

The observations include:

- Active subdomains like admin.ikman.lk, auth.ikman.lk, payment.ikman.lk, marketing.ikman.lk, support.it.ikman.lk, wiki.it.ikman.lk, etc.…
- Certifications were observable of validity of 90 days, consistent with Let's Encrypt automation.
- Separate certifications were observable for sensitive subdomains like admin, auth and payments which indicates service segmentation.
- Presence of *. it.ikman.lk and others were observable which suggest that its internal IT-related infrastructure was exposed through subdomain naming.

There was no misconfiguration observable, but the publicly visible authentication and administrative subdomains increase the reconnaissance value for the attackers.

Certificates

crt.sh ID	Logged At ⓘ	Not Before	Not After	Common Name	Matching Identities	Issuer Name
24665312945	2026-03-26	2026-03-26	2026-05-27	reports-lms.it.ikman.lk	reports-lms.it.ikman.lk	C=US, O=Let's Encrypt, CN=R13
24665292756	2026-03-26	2026-03-26	2026-05-27	reports-lms.it.ikman.lk	reports-lms.it.ikman.lk	C=US, O=Let's Encrypt, CN=R13
24591469116	2026-02-23	2026-02-23	2026-05-24	ikman.lk	*.ikman.lk ikman.lk	C=GB, O=Sectigo Limited, CN=Sectigo Public Server Authentication CA DV R36
24591468868	2026-02-23	2026-02-23	2026-05-24	ikman.lk	*.ikman.lk ikman.lk	C=GB, O=Sectigo Limited, CN=Sectigo Public Server Authentication CA DV R36
24591481199	2026-02-23	2026-02-23	2026-05-24	ikman.lk	*.ikman.lk ikman.lk	C=GB, O=Sectigo Limited, CN=Sectigo Public Server Authentication CA DV R36
24591447135	2026-02-23	2026-02-23	2026-05-24	ikman.lk	*.ikman.lk ikman.lk	C=GB, O=Sectigo Limited, CN=Sectigo Public Server Authentication CA DV R36
24299557785	2026-02-10	2026-02-10	2026-05-11	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=E7
24299381519	2026-02-10	2026-02-10	2026-05-11	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=E7
24203172989	2026-02-05	2026-02-05	2026-05-06	api.ikman.lk	api.ikman.lk	C=US, O=Let's Encrypt, CN=R12
24202167825	2026-02-05	2026-02-05	2026-05-06	api.ikman.lk	api.ikman.lk	C=US, O=Let's Encrypt, CN=R12
24123167740	2026-02-01	2026-02-01	2026-05-02	bikesguide.ikman.lk	bikesguide.ikman.lk	C=US, O=Let's Encrypt, CN=R13
24123169951	2026-02-01	2026-02-01	2026-05-02	bikesguide.ikman.lk	bikesguide.ikman.lk	C=US, O=Let's Encrypt, CN=R13
24086641049	2026-01-30	2026-01-30	2026-04-30	carsguide.ikman.lk	carsguide.ikman.lk	C=US, O=Let's Encrypt, CN=R13
24086612744	2026-01-30	2026-01-30	2026-04-30	carsguide.ikman.lk	carsguide.ikman.lk	C=US, O=Let's Encrypt, CN=R13
24045462092	2026-01-29	2026-01-28	2026-04-28	admin.ikman.lk	admin.ikman.lk	C=US, O=Let's Encrypt, CN=R12
24045366977	2026-01-29	2026-01-28	2026-04-28	admin.ikman.lk	admin.ikman.lk	C=US, O=Let's Encrypt, CN=R12
24045439730	2026-01-29	2026-01-28	2026-04-28	payment.ikman.lk	payment.ikman.lk	C=US, O=Let's Encrypt, CN=R12
24045497115	2026-01-29	2026-01-28	2026-04-28	payment.ikman.lk	payment.ikman.lk	C=US, O=Let's Encrypt, CN=R12
24045427248	2026-01-29	2026-01-28	2026-04-28	auth.ikman.lk	auth.ikman.lk	C=US, O=Let's Encrypt, CN=R12
24045419850	2026-01-29	2026-01-28	2026-04-28	auth.ikman.lk	auth.ikman.lk	C=US, O=Let's Encrypt, CN=R12
23962403451	2026-01-24	2026-01-24	2026-04-24	wiki.it.ikman.lk	wiki.it.ikman.lk	C=US, O=Let's Encrypt, CN=E8
23960405277	2026-01-24	2026-01-24	2026-04-24	wiki.it.ikman.lk	wiki.it.ikman.lk	C=US, O=Let's Encrypt, CN=E8
23943354154	2026-01-23	2026-01-23	2026-04-23	support.it.ikman.lk	support.it.ikman.lk	C=US, O=Let's Encrypt, CN=R8
23942384982	2026-01-23	2026-01-23	2026-04-23	support.it.ikman.lk	support.it.ikman.lk	C=US, O=Let's Encrypt, CN=R8
23924031159	2026-01-17	2026-01-17	2026-04-17	status.admin.ikman.lk	status.admin.ikman.lk	C=US, O=Let's Encrypt, CN=R8
23924017734	2026-01-17	2026-01-17	2026-04-17	status.admin.ikman.lk	status.admin.ikman.lk	C=US, O=Let's Encrypt, CN=R8
23797182135	2026-01-16	2026-01-16	2026-04-16	status.ikman.lk	status.ikman.lk	C=US, O=Let's Encrypt, CN=E7
23797166707	2026-01-16	2026-01-16	2026-04-16	status.ikman.lk	status.ikman.lk	C=US, O=Let's Encrypt, CN=E7
23790876010	2026-01-15	2026-01-15	2026-04-15	ikman.lk	*.ikman.lk ikman.lk	C=US, O=Google Trust Services, CN=WE1
23790875345	2026-01-15	2026-01-15	2026-04-15	ikman.lk	*.ikman.lk ikman.lk	C=US, O=Google Trust Services, CN=WE1
23790870913	2026-01-15	2026-01-15	2026-04-15	ikman.lk	*.ikman.lk ikman.lk	C=US, O=Google Trust Services, CN=WR1
23771856436	2026-01-12	2026-01-12	2026-04-12	marketing.ikman.lk	marketing.ikman.lk	C=US, O=Let's Encrypt, CN=R12
23771855082	2026-01-12	2026-01-12	2026-04-12	marketing.ikman.lk	marketing.ikman.lk	C=US, O=Let's Encrypt, CN=R12
23619002377	2026-01-10	2026-01-10	2026-04-10	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=R8
23618512132	2026-01-10	2026-01-10	2026-04-10	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=R8
23585204950	2026-01-09	2026-01-09	2026-04-09	helpcenteren.ikman.lk	helpcenteren.ikman.lk	C=US, O=Let's Encrypt, CN=R12
23585211362	2026-01-09	2026-01-09	2026-04-09	helpcenteren.ikman.lk	helpcenteren.ikman.lk	C=US, O=Let's Encrypt, CN=R12
23585268151	2026-01-09	2026-01-09	2026-04-09	helpcenterta.ikman.lk	helpcenterta.ikman.lk	C=US, O=Let's Encrypt, CN=R12
23585261393	2026-01-09	2026-01-09	2026-04-09	helpcenterta.ikman.lk	helpcenterta.ikman.lk	C=US, O=Let's Encrypt, CN=R12
23585249988	2026-01-09	2026-01-09	2026-04-09	helpcentersi.ikman.lk	helpcentersi.ikman.lk	C=US, O=Let's Encrypt, CN=R12
23585250259	2026-01-09	2026-01-09	2026-04-09	helpcentersi.ikman.lk	helpcentersi.ikman.lk	C=US, O=Let's Encrypt, CN=R12
22424667920	2025-12-28	2025-12-28	2026-03-28	reports-lms.it.ikman.lk	reports-lms.it.ikman.lk	C=US, O=Let's Encrypt, CN=R12
22424660879	2025-12-28	2025-12-28	2026-03-28	reports-lms.it.ikman.lk	reports-lms.it.ikman.lk	C=US, O=Let's Encrypt, CN=R12
23360870645	2025-12-25	2025-12-25	2026-03-25	ikman.lk	*.ikman.lk ikman.lk	C=GB, O=Sectigo Limited, CN=Sectigo Public Server Authentication CA DV R36
23360869836	2025-12-25	2025-12-25	2026-03-25	ikman.lk	*.ikman.lk ikman.lk	C=GB, O=Sectigo Limited, CN=Sectigo Public Server Authentication CA DV R36
23360798532	2025-12-25	2025-12-25	2026-03-25	ikman.lk	*.ikman.lk ikman.lk	C=GB, O=Sectigo Limited, CN=Sectigo Public Server Authentication CA DV R36
23360795832	2025-12-25	2025-12-25	2026-03-25	ikman.lk	*.ikman.lk ikman.lk	C=GB, O=Sectigo Limited, CN=Sectigo Public Server Authentication CA DV R36
23031458670	2025-12-10	2025-12-10	2026-03-10	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=E7
23016695458	2025-12-10	2025-12-10	2026-03-10	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=E7
22814288860	2025-12-07	2025-12-07	2026-03-07	api.ikman.lk	api.ikman.lk	C=US, O=Let's Encrypt, CN=R12
22768989854	2025-12-07	2025-12-07	2026-03-07	api.ikman.lk	api.ikman.lk	C=US, O=Let's Encrypt, CN=R12
22350855200	2025-12-03	2025-12-03	2026-03-03	bikesguide.ikman.lk	bikesguide.ikman.lk	C=US, O=Let's Encrypt, CN=R13
22350251371	2025-12-03	2025-12-03	2026-03-03	bikesguide.ikman.lk	bikesguide.ikman.lk	C=US, O=Let's Encrypt, CN=R13
22025847366	2025-11-01	2025-11-01	2026-03-01	carsguide.ikman.lk	carsguide.ikman.lk	C=US, O=Let's Encrypt, CN=R11
22846667577	2025-12-01	2025-12-01	2026-03-01	carsguide.ikman.lk	carsguide.ikman.lk	C=US, O=Let's Encrypt, CN=R12
22818509973	2025-11-30	2025-11-30	2026-02-28	admin.ikman.lk	admin.ikman.lk	C=US, O=Let's Encrypt, CN=R12
22813567828	2025-11-30	2025-11-30	2026-02-28	admin.ikman.lk	admin.ikman.lk	C=US, O=Let's Encrypt, CN=R12
22813553292	2025-11-30	2025-11-30	2026-02-28	payment.ikman.lk	payment.ikman.lk	C=US, O=Let's Encrypt, CN=R12
22813524966	2025-11-30	2025-11-30	2026-02-28	payment.ikman.lk	payment.ikman.lk	C=US, O=Let's Encrypt, CN=R12
22813507563	2025-11-30	2025-11-30	2026-02-28	auth.ikman.lk	auth.ikman.lk	C=US, O=Let's Encrypt, CN=R12
22813514130	2025-11-30	2025-11-30	2026-02-28	auth.ikman.lk	auth.ikman.lk	C=US, O=Let's Encrypt, CN=R12
22726609420	2025-11-25	2025-11-25	2026-02-23	wiki.it.ikman.lk	wiki.it.ikman.lk	C=US, O=Let's Encrypt, CN=E7
[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]
13605131869	2024-11-23	2024-11-23	2025-02-21	status.ikman.lk	status.ikman.lk	C=US, O=Let's Encrypt, CN=E5
13578827485	2024-11-23	2024-11-23	2025-02-21	status.ikman.lk	status.ikman.lk	C=US, O=Let's Encrypt, CN=E5
13495856623	2024-11-16	2024-11-16	2025-02-14	marketing.ikman.lk	marketing.ikman.lk	C=US, O=Let's Encrypt, CN=R10
13495741992	2024-11-16	2024-11-16	2025-02-14	marketing.ikman.lk	marketing.ikman.lk	C=US, O=Let's Encrypt, CN=R10
13406130874	2024-11-15	2024-11-15	2025-02-11	helpcenterta.ikman.lk	helpcenterta.ikman.lk	C=US, O=Let's Encrypt, CN=R11
13406138997	2024-11-15	2024-11-15	2025-02-11	helpcenterta.ikman.lk	helpcenterta.ikman.lk	C=US, O=Let's Encrypt, CN=R11
13404558358	2024-11-15	2024-11-15	2025-02-11	helpcentersi.ikman.lk	helpcentersi.ikman.lk	C=US, O=Let's Encrypt, CN=R11
13404472492	2024-11-15	2024-11-15	2025-02-11	helpcentersi.ikman.lk	helpcentersi.ikman.lk	C=US, O=Let's Encrypt, CN=R11
13404354622	2024-11-15	2024-11-15	2025-02-11	helpcenteren.ikman.lk	helpcenteren.ikman.lk	C=US, O=Let's Encrypt, CN=R10
13404471152	2024-11-15	2024-11-15	2025-02-11	helpcenteren.ikman.lk	helpcenteren.ikman.lk	C=US, O=Let's Encrypt, CN=R10
13351153862	2024-11-10	2024-11-10	2025-02-08	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=E6
13350760161	2024-11-10	2024-11-10	2025-02-08	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=E6
13287072877	2024-11-02	2024-11-02	2025-01-31	reports-lms.it.ikman.lk	reports-lms.it.ikman.lk	C=US, O=Let's Encrypt, CN=R11
13179243818	2024-11-02	2024-11-02	2025-01-31	reports-lms.it.ikman.lk	reports-lms.it.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14012168412	2024-10-18	2024-10-12	2025-11-12	collector.ikman.lk	collector.ikman.lk	C=US, O=Amazon, CN=Amazon RSA 2048 M02
14068926873	2024-10-10	2024-10-10	2025-01-08	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=E6
14068913002	2024-10-10	2024-10-10	2025-01-08	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=E6
14065160741	2024-10-10	2024-10-10	2025-01-08	bikesguide.ikman.lk	bikesguide.ikman.lk	C=US, O=Let's Encrypt, CN=R10
14065169503	2024-10-10	2024-10-10	2025-01-08	bikesguide.ikman.lk	bikesguide.ikman.lk	C=US, O=Let's Encrypt, CN=R10
14058566354	2024-10-09	2024-10-09	2025-01-07	helpcenterta.ikman.lk	helpcenterta.ikman.lk	C=US, O=Let's Encrypt, CN=R10
14058569492	2024-10-09	2024-10-09	2025-01-07	helpcenterta.ikman.lk	helpcenterta.ikman.lk	C=US, O=Let's Encrypt, CN=R10
14058562791	2024-10-09	2024-10-09	2025-01-07	helpcentersi.ikman.lk	helpcentersi.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14058581184	2024-10-09	2024-10-09	2025-01-07	helpcentersi.ikman.lk	helpcentersi.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14048605513	2024-10-06	2024-10-06	2025-01-06	helpcenteren.ikman.lk	helpcenteren.ikman.lk	C=US, O=Let's Encrypt, CN=R10
14048589975	2024-10-06	2024-10-06	2025-01-06	helpcenteren.ikman.lk	helpcenteren.ikman.lk	C=US, O=Let's Encrypt, CN=R10
14040356079	2024-10-08	2024-09-29	2024-12-28	ikman.lk	*.ikman.lk ikman.lk	C=US, O=Google Trust Services, CN=WE1
14040358611	2024-10-08	2024-10-08	2025-01-06	carsguide.ikman.lk	carsguide.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14040329685	2024-10-08	2024-10-08	2025-01-06	carsguide.ikman.lk	carsguide.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14039564295	2024-10-01	2024-10-01	2024-12-30	wiki.it.ikman.lk	wiki.it.ikman.lk	C=US, O=Let's Encrypt, CN=E6
14039559717	2024-10-01	2024-10-01	2024-12-30	wiki.it.ikman.lk	wiki.it.ikman.lk	C=US, O=Let's Encrypt, CN=E6
14027154742	2024-09-30	2024-09-30	2024-12-29	support.it.ikman.lk	support.it.ikman.lk	C=US, O=Let's Encrypt, CN=E5
14027151192	2024-09-30	2024-09-30	2024-12-29	support.it.ikman.lk	support.it.ikman.lk	C=US, O=Let's Encrypt, CN=E5
14020548445	2024-09-29	2024-09-29	2024-12-28	ikman.lk	*.ikman.lk ikman.lk	C=US, O=Google Trust Services, CN=WE1
14020539334	2024-09-29	2024-09-29	2024-12-28	ikman.lk	*.ikman.lk ikman.lk	C=US, O=Google Trust Services, CN=WR1
14002925864	2024-09-25	2024-09-25	2024-12-24	status.admin.ikman.lk	status.admin.ikman.lk	C=US, O=Let's Encrypt, CN=E5
14003018544	2024-09-25	2024-09-25	2024-12-24	status.admin.ikman.lk	status.admin.ikman.lk	C=US, O=Let's Encrypt, CN=E5
14073351143	2024-09-24	2024-09-24	2024-12-23	status.ikman.lk	status.ikman.lk	C=US, O=Let's Encrypt, CN=E6
14073319677	2024-09-24	2024-09-24	2024-12-23	status.ikman.lk	status.ikman.lk	C=US, O=Let's Encrypt, CN=E6
14085404477	2024-09-17	2024-09-17	2024-12-16	marketing.ikman.lk	marketing.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14085392898	2024-09-17	2024-09-17	2024-12-16	marketing.ikman.lk	marketing.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14085329462	2024-09-10	2024-09-10	2024-12-09	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=E5
14085318858	2024-09-10	2024-09-10	2024-12-09	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=E5
14007456662	2024-09-05	2024-09-05	2024-12-03	reports-lms.it.ikman.lk	reports-lms.it.ikman.lk	C=US, O=Let's Encrypt, CN=R10
14007548115	2024-09-05	2024-09-05	2024-12-03	reports-lms.it.ikman.lk	reports-lms.it.ikman.lk	C=US, O=Let's Encrypt, CN=R10
14035506677	2024-08-30	2024-08-30	2025-09-28	stream-collector.ikman.lk	stream-collector.ikman.lk	C=US, O=Amazon, CN=Amazon RSA 2048 M02
14147185955	2024-08-11	2024-08-11	2024-11-09	bikesguide.ikman.lk	bikesguide.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14084590029	2024-08-11	2024-08-11	2024-11-09	bikesguide.ikman.lk	bikesguide.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14141698732	2024-08-10	2024-08-10	2024-11-08	helpcentersi.ikman.lk	helpcentersi.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14091825604	2024-08-10	2024-08-10	2024-11-08	helpcentersi.ikman.lk	helpcentersi.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14141607855	2024-08-10	2024-08-10	2024-11-08	helpcenterta.ikman.lk	helpcenterta.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14077319873	2024-08-10	2024-08-10	2024-11-08	helpcenterta.ikman.lk	helpcenterta.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14139579158	2024-08-10	2024-08-10	2024-11-08	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=E5
14069408952	2024-08-10	2024-08-10	2024-11-08	*.it.ikman.lk	*.it.ikman.lk	C=US, O=Let's Encrypt, CN=E5
14122972651	2024-08-09	2024-08-09	2024-11-07	helpcenteren.ikman.lk	helpcenteren.ikman.lk	C=US, O=Let's Encrypt, CN=R10
14058950879	2024-08-09	2024-08-09	2024-11-07	helpcenteren.ikman.lk	helpcenteren.ikman.lk	C=US, O=Let's Encrypt, CN=R10
14132556394	2024-08-09	2024-08-09	2024-11-07	carsguide.ikman.lk	carsguide.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14055772473	2024-08-09	2024-08-09	2024-11-07	carsguide.ikman.lk	carsguide.ikman.lk	C=US, O=Let's Encrypt, CN=R11
14065599807	2024-08-02	2024-08-02	2024-10-31	wiki.it.ikman.lk	wiki.it.ikman.lk	C=US, O=Let's Encrypt, CN=E6
13993169922	2024-08-02	2024-08-02	2024-10-31	wiki.it.ikman.lk	wiki.it.ikman.lk	C=US, O=Let's Encrypt, CN=E6
13993151852	2024-08-01	2024-08-01	2024-10-30	ikman.lk	*.ikman.lk ikman.lk	C=US, O=Google Trust Services, CN=WR1
14004104882	2024-08-01	2024-08-01	2024-10-30	ikman.lk	*.ikman.lk ikman.lk	C=US, O=Google Trust Services, CN=WR1
14003271979	2024-08-01	2024-08-01	2024-10-30	support.it.ikman.lk	support.it.ikman.lk	C=US, O=Let's Encrypt, CN=E5
14003234122	2024-08-01	2024-08-01	2024-10-30	support.it.ikman.lk	support.it.ikman.lk	C=US, O=Let's Encrypt, CN=E5
13992481391	2024-07-26	2024-07-26	2024-10-24	status.admin.ikman.lk	status.admin.ikman.lk	C=US, O=Let's Encrypt, CN=E6
13991459633	2024-07-26	2024-07-26	2024-10-24	status.admin.ikman.lk	status.admin.ikman.lk	C=US, O=Let's Encrypt, CN=E6
13892590706	2024-07-26	2024-07-26	2024-10-24	status.ikman.lk	status.ikman.lk	C=US, O=Let's Encrypt, CN=E6
13890685885	2024-07-26	2024-07-26	2024-10-24	status.ikman.lk	status.ikman.lk	C=US, O=Let's Encrypt, CN=E6
13854341115	2024-07-19	2024-07-19	2024-10-17	marketing.ikman.lk	marketing.ikman.lk	C=US, O=Let's Encrypt, CN=R10
13808607068	2024-07-19	2024-07-19	2024-10-17	marketing.ikman.lk	marketing.ikman.lk	C=US, O=Let's Encrypt, CN=R10
[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]

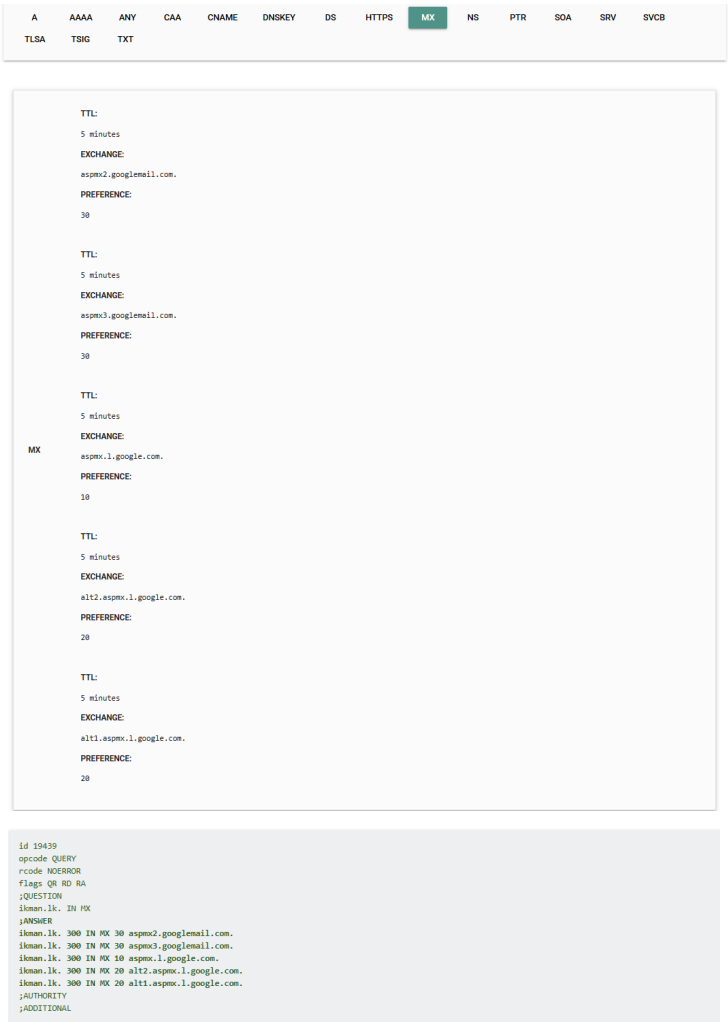
DNS Records – Using dig

DNS enumeration revealed that ikman.lk uses Cloudflare nameservers (maxine.ns.cloudflare.com, nolan.ns.cloudflare.com), confirming CDN and the reverse proxy protection.

The observations include:

- MX records point to Google Workspace mail servers, indicating managed cloud email infrastructure.
- SPF record is configured as: “v=spf1 include:_spf.google.com include:support.zendesk.com include:mail.zendesk.com include:spf.mandrillapp.com -all”, the using of “-all” indicates strict enforcement against unauthorized email sending.
- Multiple google-site-verification TXT records confirm verified domain ownership.
- Other TXT records reveal the integration with Facebook, Atlassian, and Microsoft services.

These configurations appear to be structured and properly configured, though the number of third-party integrations increases dependency exposure.



Name
ikman.lk

A AAAA ANY CAA CNAME DNSKEY DS HTTPS MX **NS** PTR SOA SRV SVCB
TLSA TSIG TXT

NS

TTL:
6 hours
TARGET:
maxine.ns.cloudflare.com.

TTL:
6 hours
TARGET:
nolan.ns.cloudflare.com.

Raw View

```
id 59010
opcode QUERY
rcode NOERROR
flags QR RD RA
;QUESTION
ikman.lk. IN NS
;ANSWER
ikman.lk. 21600 IN NS maxine.ns.cloudflare.com.
ikman.lk. 21600 IN NS nolan.ns.cloudflare.com.
;AUTHORITY
;ADDITIONAL
```

TLSA TSIG **TXT**

TXT

TTL:
5 minutes
VALUE:
"google-site-verification=fi36YHidR-jYVu8keYJ5EkzOAq6gF0gdQdky15u4e4k"

TTL:
5 minutes
VALUE:
"google-site-verification=SLFAmTUq90KccLDL_1wZOmvHjI60QomiFLG5XCyO--M"

TTL:
5 minutes
VALUE:
"google-site-verification=US-L75QWbq3VeOl_Jh9m1xaMCh1Y-Ygq_LC3KD2I6EU"

TTL:
5 minutes
VALUE:
"facebook-domain-verification=n21zhhfby9nk7935pv19f8s7h3fzba"

TTL:
5 minutes
VALUE:
"google-site-verification=1ij0NkfGrpT-O0o7pO1TjKEOaYSxUGIBe3DJ1Aw9VUU"

TTL:
5 minutes
VALUE:
"google-site-verification=u7_ibR1Rwx5YkxM0ckPnJT_qPu6S4DvGwbRjAprpin0"

TTL:
5 minutes
VALUE:
"google-site-verification=qWNu4VLDMPDytM5P31YuhemAcmVqeq3qKXAu0Rh3rwg"

TTL:
5 minutes
VALUE:
"MS=22D272132FC6A496F1FCF9430FC75BF74269C530"

```
TTL:
5 minutes
VALUE:
"MS=22D272132EC68496F1ECE9A30EC75BF74269C530"

TTL:
5 minutes
VALUE:
"34c6d145-918d-4465-a1a7-d3ddc36350be"

TTL:
5 minutes
VALUE:
"atlassian-domain-verification=G0R3XYbrRgn/GfFEPf5FkxijyWO+3ByCWOlVZ9lMthdQootdVLu/MyGYZW/2B7qM"

TTL:
5 minutes
VALUE:
"v=spf1 include:_spf.google.com include:support.zendesk.com include:mail.zendesk.com
include:spf.mandrillapp.com -all"

TTL:
5 minutes
VALUE:
"google-site-verification=6oJ9jv0XZIqKdwsWAHVvngWdJHvjiKp-BQ9LPx_jl_U"
```

Raw View

```
id 35886
opcode QUERY
rcode NOERROR
flags QR RD RA
;QUESTION
ikman.lk. IN TXT
;ANSWER
ikman.lk. 300 IN TXT "google-site-verification=fi36YHWdR-jYVW8WeYJ5EkzOAq6gF0gdQdky15u4e4k"
ikman.lk. 300 IN TXT "google-site-verification=SLFAmTUq90KccLDL_1wZOmvNjI60QomiFLGSXCyD--M"
ikman.lk. 300 IN TXT "google-site-verification=US-L75QWbq3VeDl_Jh9m1xaMCh1Y-Ygq_LC3KD2I6EU"
ikman.lk. 300 IN TXT "facebook-domain-verification=n2lzhbfby9nk7935pvt9f8s7h3frbs"
ikman.lk. 300 IN TXT "google-site-verification=1ij0NkfGrpT-O0o7pOlTjKEOaYSxUGIBe3DJ1Aw9VUU"
ikman.lk. 300 IN TXT "google-site-verification=u7_ibR1RuxSYlcxM0ckPnJT_qPu6S4DvGubRjAprpin0"
ikman.lk. 300 IN TXT "google-site-verification=qNNu4VLDMPDytM5P31YuhemAcmVqeq3qKXAu0Rh3rwg"
ikman.lk. 300 IN TXT "MS=22D272132EC68496F1ECE9A30EC75BF74269C530"
ikman.lk. 300 IN TXT "34c6d145-918d-4465-a1a7-d3ddc36350be"
ikman.lk. 300 IN TXT "atlassian-domain-verification=G0R3XYbrRgn/GfFEPf5FkxijyWO+3ByCWOlVZ9lMthdQootdVLu/MyGYZW/2B7qM"
ikman.lk. 300 IN TXT "v=spf1 include:_spf.google.com include:support.zendesk.com include:mail.zendesk.com include:spf.mandrillapp.com -all"
ikman.lk. 300 IN TXT "google-site-verification=6oJ9jv0XZIqKdwsWAHVvngWdJHvjiKp-BQ9LPx_jl_U"
;AUTHORITY
;ADDITIONAL
```

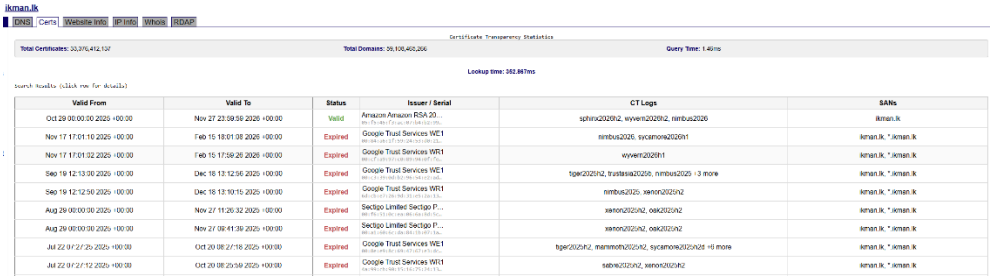

IP Space and ASN -Using BGP.he.net

This domain resolves to 104.20.46.87 and 172.66.145.108. These IP addresses belong to AS13335 (Cloudflare, Inc.), which confirms that this origin infrastructure is masked behind the Cloudflare's global CDN network.

The observations include:

- The hosting location shows as United States (Cloudflare edge nodes).
- When observing IP history it shows multiple IP changes over time, consistent with CDN routing and load balancing.
- The origin server is not exposed directly which indicates a defensive architecture.

Cloudflare protection significantly reduces direct infrastructure exposure but does not eliminate application-layer or social engineering risks.



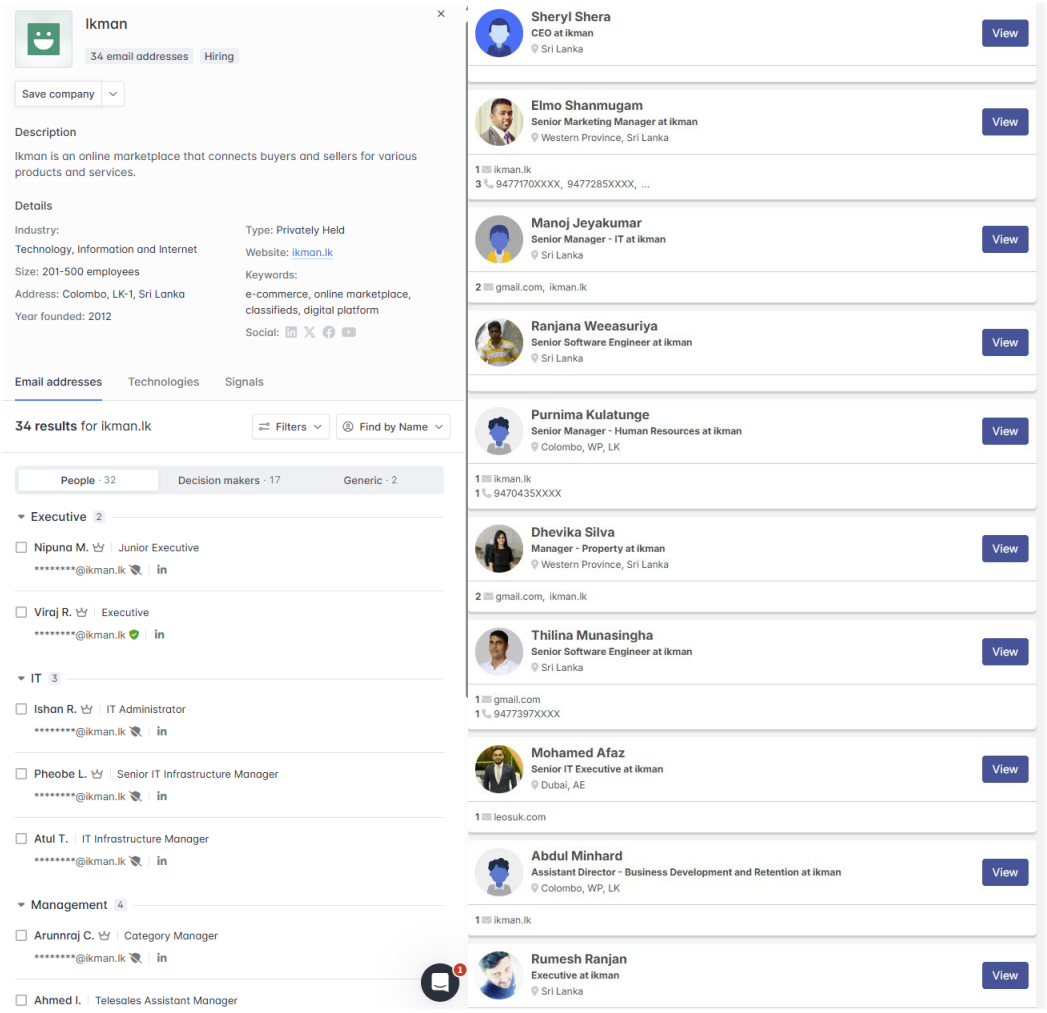
Phase B: The Human Attack Surface

Employee Mapping – Using LinkedIn and Rocket Search

Public sources such as LinkedIn and Rocket Search revealed identifiable technical roles and personal details associated with the ikman.lk, including:

- IT Infrastructure Managers
- Senior Infrastructure Engineers
- Administrative Staff
- Executive-Level Personnel

The exposure of names personal details and job titles enables targeted reconnaissance. Technical personnel represent high-value phishing targets due to access privileges and system knowledge.



Email Pattern Analysis – Using Hunter.io

Analysis of publicly available email intelligence suggests that ikman.lk uses a standardized cooperate email structure than a hybrid academics style format. According to observable results

The most commonly used pattern is, **first.last@ikman.lk** with a chance of (96.7%) and the minor variations are **first@ikman.lk** (2.5%), **firstlast@ikman.lk** (0.8%). These structured publicly exposed cooperate environments consistently increase the chance of attack. Once the identified employee names and the emails were used, attackers can reliably generate valid email addresses. This increases the exposure to:

- Spear phishing
- Business Email Compromise (BEC)

- Credential harvesting campaigns
- Social engineering attacks targeting IT and executive staff

Email Pattern Structure – ikman.lk

Pattern Type	Format	Usage Type	Risk Level
Primary Corporate Format	[first].[last]@ikman.lk	Majority of staff (96.7%)	High (Predictable)
Simplified Format	[first]@ikman.lk	Limited users (2.5%)	Medium
Compact Format	[first][last]@ikman.lk	Rare (0.8%)	Medium

ikman Email Formats and Examples

Email Format	Example	Percentage
[first].[last]	jane.doe@ikman.lk	96.7%
[first]	jane@ikman.lk	2.5%
[first][last]	janedoe@ikman.lk	0.8%

Breach History – Using HaveIBeenPwned

There was no public major credential breach directly links to ikman.lk domain was able to find during the analysis. Continuous monitoring is recommended due to third party SaaS dependencies being used.

Phase C: Document and Metadata Mining

Google Dorking

Dorks that are being used:

site: ikman.lk filetype:pdf "confidential"
site: ikman.lk filetype:docx "internal use only"

site: ikman.lk ext:backup

site: ikman.lk ext:zip

site: ikman.lk filetype:xlsx "password"

site: ikman.lk intitle:"index of"

site: ikman.lk ext:sql

site: ikman.lk inurl:admin

site: ikman.lk inurl:dashboard

site: ikman.lk filetype:pdf

site: ikman.lk filetype:docx

site: ikman.lk filetype:xlsx

site: ikman.lk filetype:pdf -inurl:pdf

Dorks that were successful:

site: ikman.lk filetype:pdf "confidential" – This returned multiple number of documents hosted under the domain of ikman.lk. Among those results a PDF document was identified that referenced a shortened external URL which redirects to a downloadable ZIP file titled ikman.lk. The observations include:

- The PDF was publicly accessible via search engines.
- Document contains third party shorten URL.
- URL redirected to a downloadable ZIP file titled ikman.lk.

Although it's not confirmed on sensitive data exposure, the presence of these publicly indexed documents referencing external downloadable files increases a huge risk of brand impersonation, phishing, malware delivery and social engineering risk.

site: ikman.lk inurl:admin – Through this it was able to reveal an accessible administrative endpoint at https://admin.ikman.lk. This page returned to the HTTP 200 OK and displayed an active administrative dashboard interface.

The observations include:

- Admin portal is publicly accessible.
- Uptime monitoring shows stable operational status.
- Endpoint is being protected behind the Cloudflare.

- Passive observation was allowed publicly.

This admin portal was discoverable with simple search engine queries which increases the reconnaissance value and attackers can use this information to target brute force attempts, credential stuffing campaigns, phishing campaigns, enumeration of authentication mechanisms. These administrative endpoints should be shielded from direct indexing and restricted through additional access controls such as IP whitelisting or VPN enforcement.

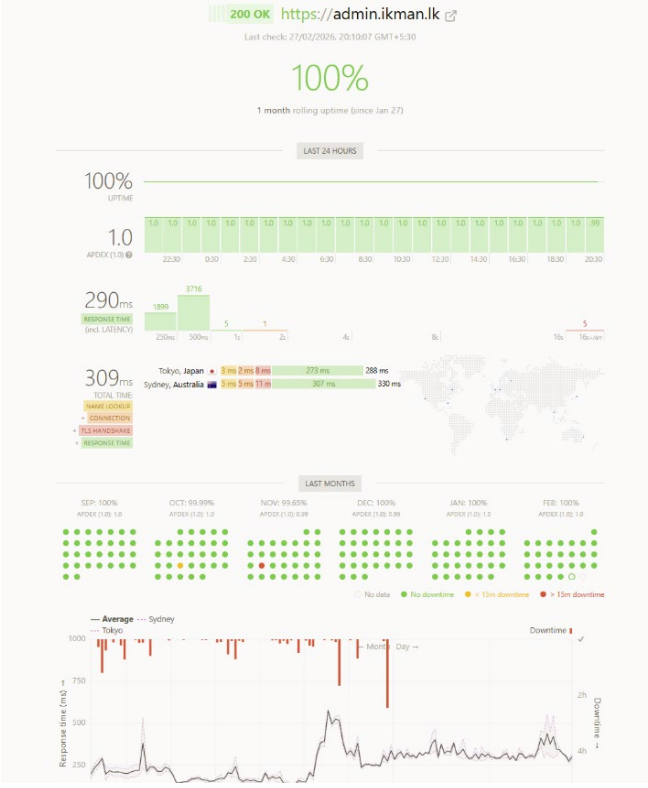
The site was initially developed by technical teams based in Sweden. The technical operations of Saltside Technologies were later moved to India, where they remain to this day. The business development and customer services for ikman.lk are managed by local staff within Sri Lanka.[3]

ikman.lk

Download File » https://tinourl.com/2xDsGz

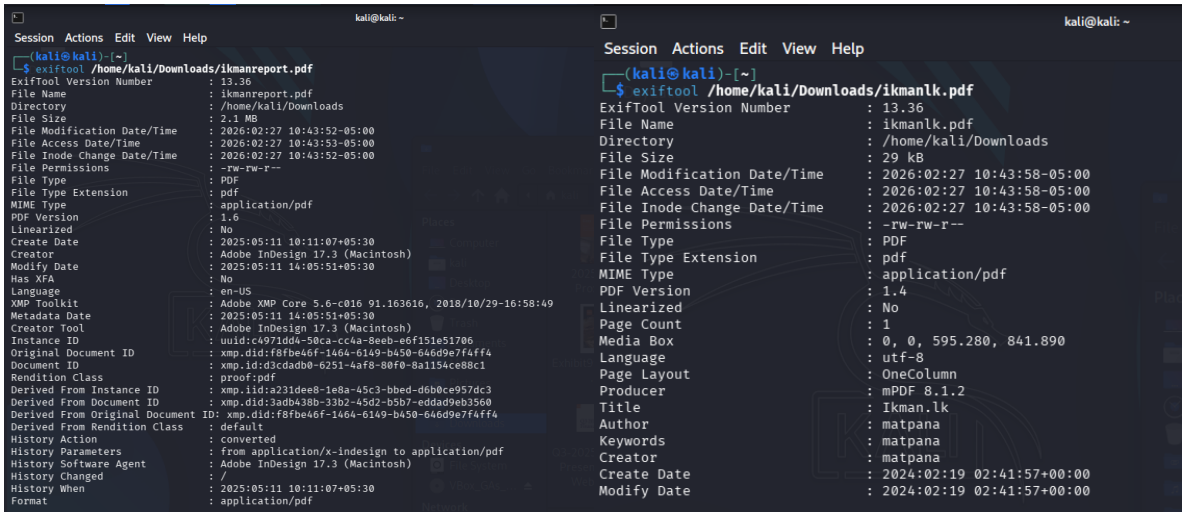
Stefan Beekmeyer, Director Marketing of ikman.lk told the Business Times that the number of visitors (2.5 million a month) at ikman.lk measures the performance of the website in Sri Lanka. 95 per cent of the visitors are from Sri Lanka and the rest from overseas which makes ikman.lk the no. 1 local site in Sri Lanka, he said.

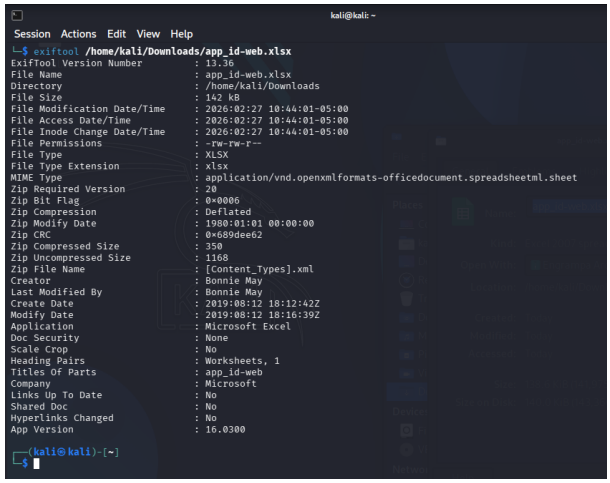
3730eaedf2



Metadata Extraction – Using ExifTool

The metadata extracted from the publicly available documents revealed some information such as authors names, creation timestamps, software identifiers (Adobe, Microsoft tools). Although there were no critical sensitive data was exposed, metadata provides contextual intelligence that can assist attackers in crafting believable phishing contents identical to the publicly available.





Phase D: Technical Stack Fingerprinting

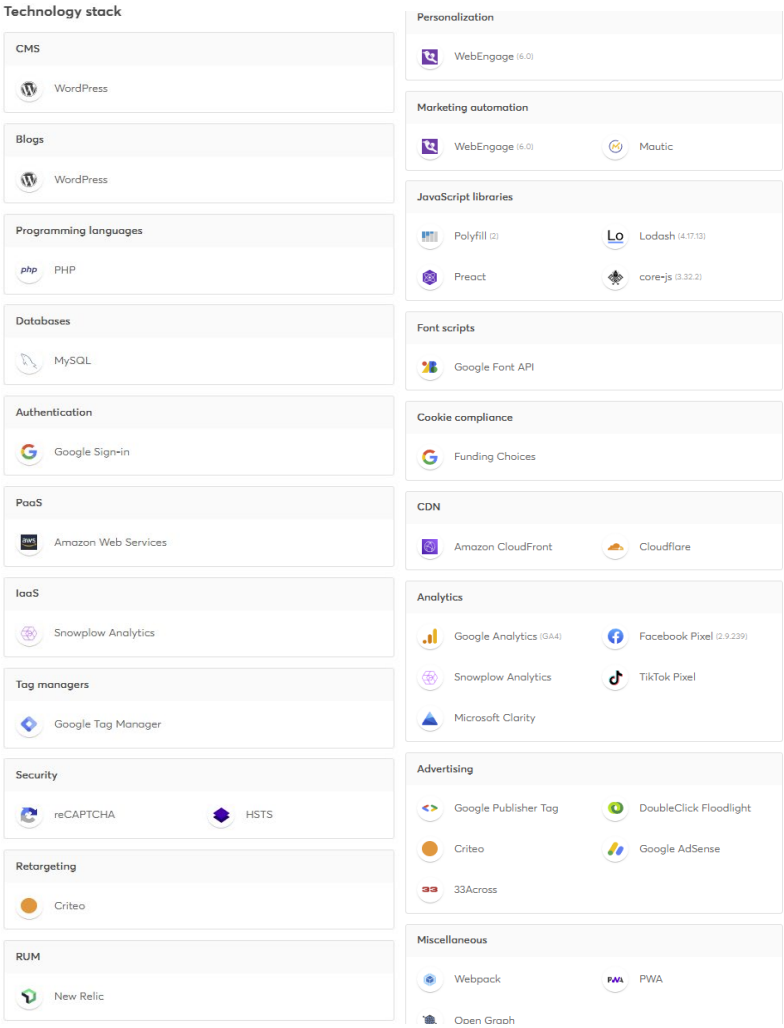
Passive Profiling – Using Wappalyzer

The technology analysis identified the following components:

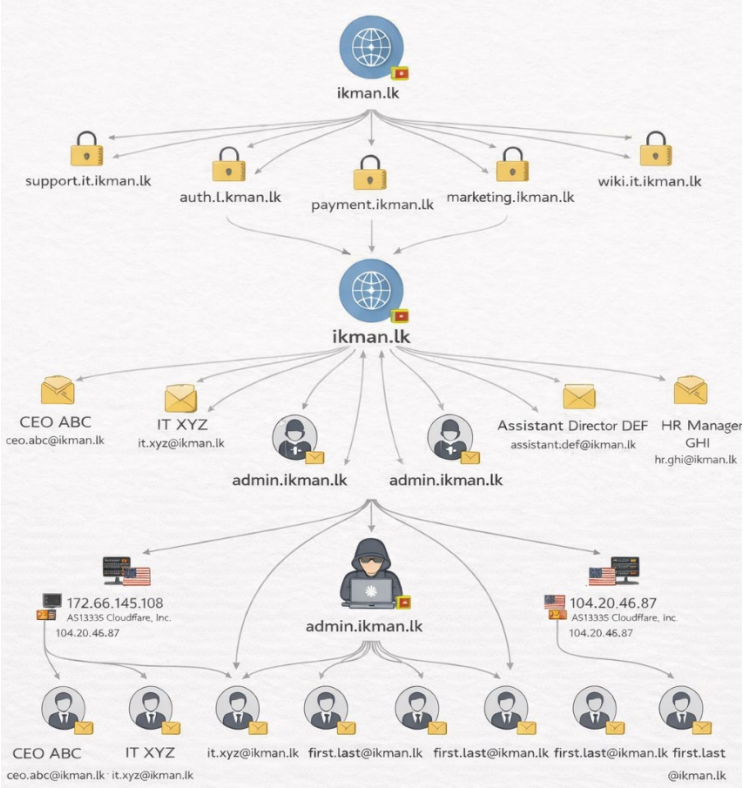
- **CMS:** WordPress
- **Backend:** PHP & MySQL

- **CDN:** Cloudflare & Amazon CloudFront
- **Cloud Infrastructure:** Amazon Web Services (AWS)
- **Analytics:** Google Analytics (GA4), Snowplow, Microsoft Clarity
- **Security:** HSTS, reCAPTCHA
- **Monitoring:** New Relic
- **Marketing Automation:** WebEngage, Mautic
- **Advertising Integrations:** Google AdSense, Criteo, DoubleClick

These environments show a modern cloud integrated architecture. The extensive use of third-party services increases the supply chain dependency risks.



Attack Surface Map



Risks Matrix

No	Vulnerability	Likelihood	Impact	Risk Level	Reason
1	Publicly Discoverable Admin Portal (admin.ikman.lk)	High	High	High	The admin endpoint is reachable and indexed via search queries. Authentication portals are prime targets for brute-force, credential stuffing, and phishing campaigns.
2	Publicly Identifiable	High	High	High	Exposed technical staff names, personal details, and predictable email patterns

	Employee Emails & Role Mapping				increase risk of spear-phishing and Business Email Compromise (BEC).
3	Publicly indexed PDF file referencing external ZIP file	Medi um	Medium - High	Mediu m - Critical	External file distribution using a shortened URL can be abused for brand impersonation or malware distribution.

Remediation

Based on the findings performing a passive reconnaissance, these actionable steps are recommended to reduce the risk of ikman.lk's publicly exposed attack surface and overall OSINT footprint.

Restriction and Securing Administrative Portals

The publicly discoverable admin portals endpoints increase the reconnaissance value and the potential targeting for the credential-based attacks.

Suggested actions to be taken:

- Restricting admin portal access using IP whitelisting or VPN only access.
- Enforcing mandatory Multi Factor Authentication (MFA) for all administrative accounts.
- Configure robots.txt and search engine directives to prevent indexing of sensitive subdomains.
- Implement rate limiting and bot detection mechanisms to prevent brute force attack attempts.

Strengthening Email Security and Reduce Human Surface Attacks

Dominant email patterns with publicly visible staff roles and personal details increase the phishing risks.

Suggested actions to be taken:

- Implementing strict DMARC enforcement with monitoring.

- Conduct regular simulations on phishing and awareness training for technical and executive staff.
- Limiting the public exposure of sensitive technical roles and personal details on external platforms where possible.
- Using role based or generic email addresses for critical functions.

Monitoring Brand Usage and Control Public File Distribution

Exposure of publicly indexed PDF's referencing shortened URLs that redirect downloadable ZIP file increases brand impersonation risks.

Suggested actions to be taken:

- Avoiding distribution and exposure of official resources through third parties.
- Implementing a brand monitoring service to detect unauthorized domain or file usage.
- Digitally signing official downloadable files to ensure authenticity.
- Regularly performing search engine monitoring to identify indexed sensitive information/documents.

Log of Tools

Infrastructure and DNS Mapping

- crt.sh: SSL certificate and subdomain enumeration
- dig: DNS record analysis (MX, TXT, NS)
- BGP.he.net: ASN and IP ownership lookup
- WHOIS: Domain registration details

Search Engine Enumeration

- Google Dorks: Indexed documents and exposed endpoints
- DuckDuckGo: General OSINT searches

Human Surface and Email Intelligence

- LinkedIn: Identification of key personnel

- Hunter.io: Email format pattern analysis
- HaveIBeenPwned: Public breach verification
- Rocket Search: key personnel details and email pattern identification.

Technology Fingerprinting and Metadata Analysis

- Wappalyzer: Technology stack identification
- ExifTool: Metadata extraction from documents

END